

منهجية تقييم ومعالجة المخاطر الأمنية

بنك الآفاق الرقمية

التصنيف: سري للغاية - داخلي

لا يجوز مشاركة هذه الوثيقة إلا داخلياً ضمن بنك الآفاق الرقمية دون تأكيد مسبق من مالك الوثيقة

Next Review	Review Frequency	Date Last Updated	Owner	Approved By	Version
2026/09/12	سنوياً	12/09/2026	مدير أمن المعلومات (CISO)	الدكتورة نورا (الرئيس التنفيذي)	0.1

الغرض من الوثيقة

توضح هذه الوثيقة النهج الشامل الذي يتبعه بنك الأفاق الرقمية لإدارة مخاطر أمن المعلومات، وذلك تنفيذاً لمتطلبات البنود 6.1.2 و 6.1.3 (هـ) و 6.2 و 8.3 من معيار ISO/IEC 27001:2022.

الغرض منها توجيه الجوانب الجوهرية لإدارة المبادئ الأساسية لمخاطر أمن المعلومات، بما يشمل تحديد المخاطر وتقييمها وترتيب أولوياتها ومعالجتها ومراقبتها المستمرة.

محتوى هذه الوثيقة موجّه للموظفين، والمراجعين (الداخليين والخارجيين)، والموردين، والعملاء عند الحاجة. يمكن الرجوع إلى السياسات والإجراءات المرتبطة (سياسة أمن المعلومات، إجراء إدارة الحوادث) للحصول على تفاصيل داعمة إضافية.

سجل المخاطر

يوجد سجل مخاطر أمن المعلومات ضمن أداة "تقييم ومعالجة المخاطر القائم على الأصول" (ISMS-FORM-06-1) المعتمدة لدى إدارة أمن المعلومات، ويُعد المرجع الوحيد والموثوق لتفاصيل كل خطر وخطة معالجته طوال مراحل العملية.

يقتصر الوصول إلى سجل المخاطر على:

- مدير أمن المعلومات (CISO) وفريق تقييم المخاطر والثغرات - وصول كامل للتعديل والاعتماد.
- أصحاب المخاطر (رؤساء الإدارات المعنية: تقنية المعلومات، الإدارة المالية، الموارد البشرية، العمليات المصرفية الدولية) - وصول للاطلاع والتحديث على المخاطر الخاصة بمجالاتهم فقط.
- إدارة المراجعة الداخلية ومراجعو الجهات الخارجية (مثل استشاري فحص الثغرات) - وصول للاطلاع فقط، ضمن نطاق مهمة المراجعة أو التدقيق المحددة.
- الرئيس التنفيذي ومجلس الإدارة - يطلعون على ملخصات دورية للمخاطر عالية الخطورة والحرجة ضمن تقارير مراجعة الإدارة.

الأدوار والمسؤوليات

مجموعة أمن المعلومات (تتمثل في اللجنة الإشرافية للإدارة العليا برئاسة الرئيس التنفيذي، بدعم من إدارة المخاطر المؤسسية):

- وضع سياسة إدارة المخاطر وأهدافها ومستوى قبول المخاطر (Risk Appetite) الخاص بالبنك.
- تخصيص الموارد اللازمة (بما يشمل الميزانية السنوية لأمن المعلومات) لدعم عملية معالجة المخاطر.
- ضمان توافق أنشطة معالجة المخاطر مع الأهداف الاستراتيجية العامة للبنك، خاصة في ظل المنافسة المتزايدة من البنوك الرقمية.

أصحاب المخاطر (مثل مدير تقنية المعلومات، مدير الإدارة المالية، مدير الموارد البشرية، مدير العمليات المصرفية الدولية):

- تحديد وتقييم المخاطر المرتبطة بمجالات مسؤوليتهم المحددة.
- تحديد معايير المخاطر ومستويات القبول المناسبة لأعمالهم.
- اختيار خيار المعالجة المناسب (قبول، تجنب، نقل، أو تخفيف) بما يتماشى مع مستوى قبول المخاطر ومعايير البنك.
- تنفيذ خطط معالجة المخاطر ومتابعتها.
- رفع تقارير دورية عن التقدم في معالجة المخاطر إلى مدير أمن المعلومات.

مدير أمن المعلومات (CISO - الأستاذة سارة الحربي):

- تطوير منهجية معالجة المخاطر والأدوات والتقنيات المرتبطة بها والحفاظ عليها.
- تقديم التوجيه والدعم لأصحاب المخاطر والأطراف المعنية خلال عملية المعالجة.
- مراقبة التقدم العام لمعالجة المخاطر وفعاليتها عبر فرق الحوكمة والعمليات الأمنية (SOC) والاستجابة للحوادث.
- رفع تقارير دورية عن عملية معالجة المخاطر إلى الإدارة العليا ومجلس الإدارة.
- تنسيق أنشطة معالجة المخاطر بين مختلف الإدارات.

ملخص المنهجية

يُقسّم نهج إدارة المخاطر إلى خمس خطوات رئيسية متسلسلة:

1. تحديد المخاطر (Risk Identification) — رصد المخاطر المحتملة من مصادر متعددة.
2. تقييم المخاطر (Risk Assessment) — تقدير احتمالية وأثر كل خطر.
3. ترتيب أولويات المخاطر (Risk Prioritisation) — تصنيف المخاطر حسب درجتها الإجمالية.
4. معالجة المخاطر (Risk Mitigation/Treatment) — اختيار وتنفيذ إجراءات المعالجة المناسبة.
5. مراقبة المخاطر (Risk Monitoring) — المتابعة والمراجعة المستمرة وتحديث السجل.

تُطبّق هذه الخطوات الخمس بشكل متكامل مع أداة تقييم ومعالجة المخاطر (ISMS-FORM-06-1) المستخدمة فعلياً لتوثيق كل خطر عبر هذه المراحل الخمس.



تحديد المخاطر

يمكن أن يأتي تحديد مخاطر أمن المعلومات من طرق متعددة، تشمل - على سبيل المثال لا الحصر - داخل بنك الأفاق الرقمية:

- **المراجعة السنوية لسياق البنك** - أي تغييرات في النطاق أو الأطراف المعنية أو التشريعات (مثل تحديثات أنظمة ساما أو سدايا) قد تُدخل مخاطر جديدة.
- **مراقبة التهديدات الناشئة** - من خلال تنبيهات الموردين الأمنيين، تحديثات الإعلام، وإشعارات جهات مثل الهيئة الوطنية للأمن السيبراني السعودية (NCA). يُعد هذا حالياً أحد مجالات التحسين ذات الأولوية للبنك، إذ لا توجد حتى الآن عملية منهجية لجمع معلومات التهديدات.
- **تحليل SWOT** - مراجعة نقاط القوة والضعف والفرص والتهديدات؛ يُجري البنك هذا التحليل سنوياً لأبرز التهديدات.
- **إشراك الأطراف المعنية** - التغذية الراجعة من الموظفين والعلماء والموردين (وفق سجل الأطراف المعنية المعتمد لدى البنك).
- **عمليات المراجعة الأمنية** - المراجعات الخارجية، واختبارات الاختراق وفحص الثغرات. يستعين البنك حالياً باستشاري خارجي متخصص لإجراء فحص ثغرات ربع سنوي.
- **تقييم مخاطر الأنظمة الحرجة** - مراجعة شاملة لمكونات الأنظمة المصرفية الأساسية (مثل تطبيق آفاق بلس والنظام المصرفي الأساسي) والمخاطر المحتملة على استمرار تشغيلها.

يجب الإبلاغ عن المخاطر إلى فريق الدعم الفني (إذا كانت من خارج نطاق تقنية المعلومات) وتسجيلها في سجل المخاطر، الذي يُعد المرجع الوحيد والموثوق لتفاصيل الخطر وخطة معالجته طوال مراحل العملية.

تقييم المخاطر

يُقيّم كل خطر بناءً على احتماليته وأثره. تشير الاحتمالية إلى مدى إمكانية وقوع الخطر، بينما يمثل الأثر العواقب المحتملة في حال تحقق هذا الخطر.

اختار بنك الآفاق الرقمية استخدام مقاييس القياس التالية:

الاحتمالية	الوصف	الدرجة
نادر الحدوث	- يُعتبر حدوث هذا الخطر مستبعداً في الظروف العادية. - لا توجد حالات معروفة، أو حالات نادرة جداً في مؤسسات مصرفية مشابهة. - تُستخدم هذه الفئة عادة للمخاطر النظرية أو الضئيلة الأثر.	1
غير مرجح	- احتمالية حدوث الخطر منخفضة. - يحدث في ظروف استثنائية لكنه لا يُتوقع تكراره بانتظام. - تصنيف مناسب للمخاطر المعروفة لكن غير الشائعة في القطاع المصرفي السعودي.	2
محتمل	- احتمالية حدوث الخطر متوسطة. - هناك احتمال متساو لحدوث الخطر أو عدم حدوثه. - يمثل احتمالاً واقعياً في البيئة الحالية للبنك ويستحق قدراً معقولاً من الاهتمام.	3
مرجح	- الخطر أكثر عرضة للحدوث من عدمه. - سبق أن وقعت حوادث مشابهة لهذا الخطر فعلياً في البنك أو في سياقات مشابهة (كما في القسم 4 من دراسة الحالة). - يتطلب إدارة ومراقبة استباقية.	4
شبه مؤكد	- الخطر شبه مؤكد الحدوث. - أدلة قوية أو بيانات تاريخية فعلية تشير إلى تكرار هذا الخطر في بيئة البنك (مثل نتائج محاكاة التصيد المتكررة). - يستدعي إجراءات تخفيف فورية وفعالة كأولوية قصوى.	5

الدرجة	مستوى الأثر	الوصف
1	ضئيل	- الأثر لا يُذكر، دون عواقب ملموسة على العمليات أو السمعة أو الوضع المالي. - لا يسبب أي توقف للأنشطة الاعتيادية ولا يتطلب جهداً يُذكر لمعالجته.
2	طفيف	- يسبب إزعاجاً بسيطاً يمكن التعامل معه أو حله عبر الإجراءات الروتينية. - قد ينتج عنه تأخير طفيف أو تكاليف محدودة، دون تأثير يُذكر على أهداف البنك.
3	متوسط	أثر ملحوظ قد يسبب بعض التعطل، لكن يمكن التعامل معه دون صعوبة كبيرة. قد ينطوي على تكاليف مالية متوسطة أو انخفاض مؤقت في الإنتاجية، ويتطلب اهتمام الإدارة لكنه ضمن قدرة البنك على المعالجة.
4	كبير	- يسبب تعطلاً كبيراً في الخدمات أو العمليات المصرفية. قد يؤدي لخسارة مالية جوهرية، أو ضرر بالغ بالسمعة، أو مخالفة تنظيمية أمام ساما أو سدايا. - يتطلب التعافي منه جهداً كبيراً وقد يؤثر على الأهداف الاستراتيجية للبنك (كما في حادثتي انقطاع الخدمة وانتهاء شهادة TLS، القسم 4.1، 4.4).
5	كارثي	- الأثر شديد الخطورة لدرجة تهديد استمرارية البنك وجوده. قد يؤدي لضرر طويل الأمد أو دائم بسمعة البنك أو استقراره المالي أو مكانته في السوق. - قد ينطوي على تبعات قانونية جسيمة، وخسائر مالية كبيرة، وضرر حرج بأصول البنك أو علاقاته مع الأطراف المعنية (كساما والعملاء).

ترتيب أولويات المخاطر

يقوم بنك الأفاق الرقمية بترتيب المخاطر بناءً على احتمالياتها وأثرها للمساعدة في التركيز على أهمها. باستخدام حاصل ضرب (الأثر × الاحتمالية)، يُحصل على تصنيف إجمالي لكل خطر. الأولويات القصوى هي مخاطر الربع ذي الاحتمالية العالية والأثر العالي معاً.

الأثر \ الاحتمالية	1	2	3	4	5
كارثي (5)	5	10	15	20	25
كبير (4)	4	8	12	16	20
متوسط (3)	3	6	9	12	15
طفيف (2)	2	4	6	8	10
ضئيل (1)	1	2	3	4	5

أخضر: مخاطر ضئيلة يجب حلها لكنها لا تسبب مشاكل تشغيلية ملحوظة.

أصفر: مخاطر منخفضة نسبياً تسبب إزعاجاً يمكن التعامل معه.

برتقالي: مخاطر عالية تهدد استمرار الخدمات التشغيلية.

أحمر: مخاطر حرجية/شديدة الخطورة تهدد استمرارية عمل البنك ويجب معالجتها فوراً.

معالجة (تخفيف) المخاطر

سيضع فريق أمن المعلومات استراتيجيات لإدارة المخاطر المُرتَّبة حسب الأولوية. هناك أربعة أساليب رئيسية لمعالجة المخاطر:

- **القبول (Accept):** إذا كان الخطر منخفض الاحتمالية والأثر، قد يكون من المقبول الإقرار به ومراقبته دون إجراء إضافي.
- **التجنب (Avoid):** تغيير الخطط، حيثما أمكن، لتجنب الخطر بالكامل.
- **النقل (Transfer):** تحويل الخطر لطرف آخر (مثل التأمين السيبراني أو التعاقد الخارجي مع ضمانات تعاقدية).
- **التخفيف (Mitigate):** تنفيذ إجراءات لتقليل احتمالية و/أو أثر الخطر (مثل تدريب إضافي، خطط احتياطية، تنويع الموردين).

تُوضع خطط معالجة المخاطر وتُراقب، ويُحدَّد مالك مسؤول عن حل كل خطر إلى مستوى مُرضٍ يرتاح له البنك.

يجب أن يوثَّق سجل المخاطر بوضوح خيار المعالجة المُختار (قبول، تجنب، نقل، تخفيف) لكل خطر، مع تبرير كل قرار استناداً إلى نتيجة التقييم ومستوى قبول المخاطر لدى البنك.

خيار المعالجة	التوثيق
القبول	تقديم تبرير لقبول الخطر، متضمناً تحليل التكلفة مقابل العائد عند الإمكان (مثال: قبول خطر منخفض الأثر يتعلق بتوقف مؤقت لخدمة داخلية غير حرجية).
التجنب	وصف التغييرات التي أُجريت على الخطط أو العمليات لتجنب الخطر (مثال: إلغاء استخدام مورد تقني لا يستوفي المتطلبات الأمنية).
النقل	تفصيل آليات نقل الخطر، مثل التأمين السيبراني أو التعاقد الخارجي، والاتفاقيات المرتبطة بذلك.
التخفيف	توضيح الإجراءات المحددة المتخذة لتقليل الخطر، بما يشمل الضوابط التقنية والإدارية والمادية (كما هو موثق في عمود "إجراء المعالجة المقترح" بسجل المخاطر).

تُسجَّل قرارات معالجة المخاطر في سجل المخاطر، ويعتمدها صاحب الخطر المعني، ويراجعها مدير أمن المعلومات (CISO).

معايير قبول المخاطر

تُعرّف معايير قبول المخاطر بأنها مستوى الخطر الذي يكون البنك مستعداً لقبوله دون معالجة إضافية. تُعتمد هذه المعايير من الإدارة العليا استناداً إلى مستوى قبول المخاطر لدى البنك وأهدافه الاستراتيجية.

توحيداً مع درجات المخاطر المستخدمة فعلياً في أداة تقييم ومعالجة المخاطر (ISMS-FORM-06-1) المعتمدة لدى البنك (حيث الدرجة = الاحتمالية × الأثر، من 1 إلى 25)، تم اعتماد معايير القبول التالية:

مستوى الخطر	المعيار
منخفض (الدرجة 1-4)	مقبول دون معالجة إضافية، لكن يجب مراقبته ضمن سجل المخاطر.
متوسط (الدرجة 5-11)	قد يُقبل إذا كانت تكلفة المعالجة تفوق الفائدة المتوقعة منها؛ يتطلب موافقة الإدارة المعنية (صاحب الخطر).
عالٍ (الدرجة 12-19)	يتطلب إجراءات تخفيف لتقليل الخطر إلى مستوى مقبول. لا يمكن قبوله دون خطة معالجة شاملة وموافقة مدير أمن المعلومات.
حرج/شديد الخطورة (الدرجة 20-25)	غير مقبول إطلاقاً. يتطلب إجراءً فورياً للتخفيف أو النقل، ويُصعد وجوباً إلى الإدارة العليا ومجلس الإدارة.

ملاحظة للاتساق: هذا التدرج الرباعي (منخفض/متوسط/عالٍ/حرج) يتوافق تماماً مع حدود "Risk Level" المحسوبة تلقائياً في أداة تقييم المخاطر (LOW حتى 4، MEDIUM من 5 إلى 11، و HIGH ابتداءً من 12)، مع إضافة فئة فرعية "حرج" ضمن نطاق HIGH (من 20 إلى 25) لأغراض التصعيد الإلزامي فقط، دون تعديل الصيغ الحسابية المعتمدة في الأداة نفسها.

تُراجع هذه المعايير وتُعتمد من قبل مجموعة أمن المعلومات، وتُعاد مراجعتها سنوياً أو عند حدوث تغييرات جوهرية (مثل تغييرات تنظيمية من ساما أو توسع كبير في الخدمات الرقمية).

مراقبة المخاطر

تُراقب المخاطر وتُراجع باستمرار، مع تحديث تقييم المخاطر كلما تطورت الظروف وتعديل خطط المعالجة وفقاً لذلك.

تساعد المراجعات الدورية للمخاطر على ضمان بقاء البنك استباقياً في إدارة المخاطر وأن يظل نهجه فعالاً. يُوصى بمراجعة سجل المخاطر بالكامل كل ثلاثة أشهر على الأقل، مع مراجعة فورية عند وقوع أي حادث أمني جديد (كما حدث في الحوادث الموثقة سابقاً) أو تغيير جوهري في البيئة التشغيلية أو التنظيمية للبنك.

خطط المعالجة

في نهج بنك الأفاق الرقمية لإدارة مخاطر أمن المعلومات ومعالجتها، يُعتمد أسلوب قائم على عتبة معينة لضمان معالجة كل خطر بالمستوى المناسب من التفصيل والاهتمام.

وفقاً لتقييم الاحتمالية والأثر المجمع، فإن المخاطر التي تتجاوز درجتها 11 (أي المصنفة HIGH أو الحرجة) تستوجب إعداد خطة معالجة شاملة ومفصلة. توفر هذه الخطط استراتيجيات وإجراءات متعمقة مصممة خصيصاً لطبيعة كل خطر مرتفع الدرجة وتعقيده، لضمان معالجة قوية وفعالة.

أما استراتيجيات التخفيف وإجراءات الضبط الخاصة بالمخاطر التي تكون درجتها 11 أو أقل، فتوثق مباشرة داخل سجل المخاطر نفسه (في عمودي "إجراء المعالجة المقترح" و "مرجع ضابط الملحق A"). يتيح هذا النهج الحفاظ على سجل مخاطر مختصر وقابل للإدارة، مع تخصيص مزيد من التخطيط التفصيلي والموارد للمخاطر التي تشكل تهديداً أكبر على وضع أمن المعلومات في البنك.

تتماشى هذه المنهجية مع التزام البنك بعملية إدارة مخاطر استباقية ومرتبطة حسب الأولوية، بما يضمن معالجة المخاطر الأكثر أهمية بخطط شاملة ومحددة.

استناداً إلى سجل المخاطر الحالي لبنك الأفاق الرقمية، فإن المخاطر التالية تتجاوز درجة 11 وتستوجب خطط معالجة مفصلة مستقلة:

- خطر هجوم التصيد الاحتيالي الموجّه لموظفي الإدارة المالية (الدرجة 20 - المرجع R4 في سجل المخاطر).
- خطر استغلال ثغرات حقن SQL في تطبيق آفاق بلس (الدرجة 16 - المرجع R1).
- خطر انقطاع الخدمة نتيجة خطأ بشري في تحديثات جدار الحماية (الدرجة 16 - المرجع R2).
- خطر هجوم التصيد الاحتيالي العام على جميع الموظفين (الدرجة 15 - المرجع R13).
- خطر هجوم الفدية على قاعدة بيانات العملاء الرئيسية (الدرجة 15 - المرجع R7).

يجب إرفاق خطة المعالجة التفصيلية بسجل الخطر ضمن سجل المخاطر لكل خطر من هذه المخاطر.

التصعيد

يجب تصعيد أي خطر يُصنّف ضمن فئة "حرج/شديد الخطورة" (الدرجة 20-25) عبر الهيكل الإداري إلى إدارة المخاطر المؤسسية، ليُدْرَج ضمن سجل المخاطر المؤسسي للبنك ويُعرَض على مجلس الإدارة.

بالنسبة للمخاطر المصنّفة "عالي" (الدرجة 12-19)، يُصعّد الخطر إلى الرئيس التنفيذي ومدير أمن المعلومات (CISO) للاعتماد على خطة المعالجة والموافقة على الموارد اللازمة لتنفيذها.

يجب أن تشمل عملية التصعيد إشعاراً فورياً للجهات التنظيمية ذات العلاقة (البنك المركزي السعودي - ساما، أو هيئة البيانات والذكاء الاصطناعي - سدايا) متى ما كان الخطر أو الحادث المرتبط به يستوجب ذلك وفقاً لالتزامات البنك التنظيمية، أسوة بما جرى فعلياً في حادثة فقدان الجهاز المحمول الموثقة سابقاً.